

ISO 27001:2022 controls			Applicability (YES/NO)	Justification for selection/non-selection	Implementation method	Status
Theme	No.	Control objective/Control				
Organizational controls	5.10					
	5.12	Classification of information	Yes	Risks #45, 89, and 125; Agreement with company XYZ	Documented in the Classification Policy	Implemented
	5.13	...				
Physical controls	7.5	...				
	7.6	Working in secure areas	No	Control not applicable because of the nature of our business. The company doesn't have or use secure areas. There is not even a server room, because cloud servers are used.	N/A	N/A

Example:

Risk Treatment Plan: What actions will we take? Actions/controls, reference to risks, risk owner, deadline for implementation, required resources and results of implementation. Approval by the risk owner must be obtained.

6.2 Security Objectives: Define measurable security goals. **Example:** "Reduce security incidents by 20% within one year."

Mandatory documentation: objective, measurement/KPI, responsible person, resources, deadline, evaluation method.

6.3 Changes: Plan ISMS changes before implementing them.

7 Support

7.1 Resources: Provide enough people, time, budget, and technology for ISMS.

7.2 Competence: Employees must have required skills. **Mandatory evidence of competence:** e.g. training records, certificates, qualifications, experience.

7.3 Awareness: Employees understand security responsibilities. **Practical document:** Awareness training records.

7.4 Communication: Define what, when, how, and with whom to communicate security information. Internal & external.

Practical document: Communication plan.

7.5 Documentation: Maintain required ISMS documents. Control access, storage, changes, retention (how long to keep), and disposal (how to remove).

8 Do / Operation

8.1 Operational Control: Implement and control what was planned in Clause 6.

Example - Data backup:

- CISO identifies data types, defines appropriate backup frequency, documents the backup policy, ensures it is followed.
- System Administrator implements the technical controls.

Practical document: Policies, procedures, tickets, configurations, logs.

8.2 Risk Assessment: Repeat risk assessments periodically and after major changes.

Mandatory: Update risk assessment results.

8.3 Risk treatment: Implement the Risk Treatment Plan. **Mandatory documentation:** Risk treatment results.

9 Check / Performance Evaluation

9.1 Monitoring: Measure whether the ISMS and controls are effective. **Mandatory records:** Monitoring/measurement results, e.g. KPIs (Key Performance Indicator), incident statistics, reports.

KPI example: % of employees completing security training.

9.2 Internal Audit: Check whether audit criterias are followed at planned intervals.

Audit criteria: Organization's own ISMS requirements + ISO 27001 requirements. Auditors must be objective and impartial.

Mandatory documentation: Audit programme + audit results.

9.3 Management Review: Top Management reviews ISMS performance and problems.

Mandatory documentation: Management Review results.

10 Act / Improvement:

10.1 Continual Improvement: Improve the suitability, adequacy and effectiveness of the ISMS. Use results/audits.

10.2 Corrective Action: Fix nonconformities and their root causes. **Nonconformity:** A requirement is not met or a rule is not followed. **Mandatory documentation:** Corrective Action records.

Best practices:

Keep documents simple. Delete unnecessary documents.

Assign an owner to each document. Document owners should review documents regularly and recommend updates.

6 - Annex A:

List of controls for treat information security risks.

Controls do not include details. ISO 27002 gives useful guidance to implementation of controls.

Choose control based on your needs and resources etc.

Security controls grouped into **4 sections**:

A.5 Organizational controls: 37 Controls. Requires documenting operational procedures that will be available to everyone in the organization who needs them.

A.5.1 Policies for Information Security: Define, approve and regularly review security policies.

A.5.2 Information Security Roles and Responsibilities: Define who is responsible for security tasks.

A.5.3 Segregation of Duties: Separate conflicting responsibilities to reduce misuse or errors.

A.5.4 Management Responsibilities: Management ensures employees follow security requirements.

A.5.5 Contact with Authorities: Maintain contact with relevant authorities when needed.

A.5.6 Contact with Special Interest Groups: Maintain contact with security groups and professional communities.

A.5.7 Threat Intelligence: Collect and analyze information about security threats.

A.5.8 Information Security in Project Management: Include security requirements in projects.

A.5.9 Inventory of Information and Other Associated Assets: Maintain an inventory of important information & assets.

A.5.10 Acceptable Use of Information and Assets: Define rules for acceptable use of information and assets.

A.5.11 Return of Assets: Employees must return company assets when required, e.g. when leaving.

A.5.12 Classification of Information: Classify information based on sensitivity and importance.

A.5.13 Labelling of Information: Label information according to its classification.

A.5.14 Information Transfer: Protect information when it is transferred internally or externally.

A.5.15 Access Control: Define rules for granting and restricting access.

A.5.16 Identity Management: Manage user identities throughout their life cycle.

A.5.17 Authentication Information: Protect passwords, keys and other authentication information.

A.5.18 Access Rights: Grant, review, change and remove access rights appropriately.

A.5.19 Information Security in Supplier Relationships: Manage security risks related to suppliers.

A.5.20 Security within Supplier Agreements: Include security requirements in supplier contracts.

A.5.21 ICT Supply Chain Security: Manage security risks in the ICT supply chain.

A.5.22 Monitoring Supplier Services: Monitor, review and control changes in supplier services.

A.5.23 Cloud Services Security: Manage security when acquiring, using and terminating cloud services.

A.5.24 Incident Management Planning: Define responsibilities and procedures before incidents occur.

A.5.25 Assessment of Security Events: Evaluate security events and decide whether they are incidents.

A.5.26 Response to Security Incidents: Respond to and manage security incidents.

A.5.27 Learning from Security Incidents: Use incidents to improve security and prevent recurrence.

A.5.28 Collection of Evidence: Collect and preserve evidence properly after incidents.

A.5.29 Security During Disruption: Maintain information security during disruptions or crises.

A.5.30 ICT Readiness for Business Continuity: Prepare IT systems to support business continuity.

A.5.31 Legal, Regulatory and Contractual Requirements: Identify and comply with applicable requirements.

A.5.32 Intellectual Property Rights: Protect copyrights, licenses and other intellectual property.

A.5.33 Protection of Records: Protect important records against loss, damage or unauthorized access.

A.5.34 Privacy and Protection of PII: Protect personal data and comply with privacy requirements.

A.5.35 Independent Review of Information Security: Have security independently reviewed at planned intervals or after major changes.

A.5.36 Compliance with Security Policies and Standards: Check whether security policies, rules and standards are followed.

A.5.37 Documented Operating Procedures: Document important operational procedures where necessary.

A.6 People controls: 8 Controls.

People are aware of their responsibilities regarding information security, have the necessary training, and will take proper measures to protect the information.

A.7 Physical controls: 14 Controls.

Controls for securing the area, and controls for securing the equipment.

A.8 Technological controls: 34 Controls.

Capacity management, network security, cryptography.

A.8.1 User Endpoint Devices: Protect laptops, phones and other user devices.

A.8.2 Privileged Access Rights: Strictly control and limit admin/privileged accounts.

A.8.3 Information Access Restriction: Allow access only to authorized information.

A.8.4 Access to Source Code: Restrict access to source code and development tools.

A.8.5 Secure Authentication: Use secure authentication, e.g. strong passwords and MFA.

A.8.6 Capacity Management: Ensure systems have enough resources and capacity.

A.8.7 Protection Against Malware: Protect systems against malicious software.

A.8.8 Management of Technical Vulnerabilities: Identify and fix technical vulnerabilities, e.g. patching.

A.8.9 Configuration Management: Define, implement and control secure system configurations.

A.8.10 Information Deletion: Delete information when it is no longer required.

A.8.11 Data Masking: Hide sensitive data to limit exposure.

A.8.12 Data Leakage Prevention: Prevent and detect unauthorized disclosure of sensitive data.

A.8.13 Information Backup: Create and regularly test backups.

A.8.14 Redundancy: Use redundant systems where needed to maintain availability.

A.8.15 Logging: Record important system and security events.

A.8.16 Monitoring Activities: Monitor systems and networks for unusual or suspicious activity.

A.8.17 Clock Synchronization: Synchronize system clocks to reliable time sources.

A.8.18 Privileged Utility Programs: Restrict powerful tools that can bypass security controls.

A.8.19 Software Installation: Control software installation on operational systems.

A.8.20 Network Security: Secure and manage networks and network devices.

A.8.21 Security of Network Services: Define and monitor security requirements for network services.

A.8.22 Segregation of Networks: Separate networks where necessary, e.g. guest and internal networks.

A.8.23 Web Filtering: Control website access to reduce exposure to malicious content.

A.8.24 Use of Cryptography: Define and correctly use encryption and cryptographic controls.

A.8.25 Secure Development Life Cycle: Integrate security throughout software development.

A.8.26 Application Security Requirements: Define security requirements before developing or acquiring applications.

A.8.27 Secure Architecture and Engineering: Apply security principles when designing systems.

A.8.28 Secure Coding: Apply secure coding practices to reduce software vulnerabilities.

A.8.29 Security Testing: Test security during development and before acceptance/release.

A.8.30 Outsourced Development: Control and monitor externally developed software.

A.8.31 Separation of Environments: Separate development, testing and production environments.

A.8.32 Change Management: Review, approve and control system changes.

A.8.33 Test Information: Protect test data and use it securely.

A.8.34 Protection During Audit Testing: Protect operational systems and data during technical audit tests.